

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
I	PRELIMINARY	See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	
II	ESTABLISHMENT OF THE OFFICE OF DATA PROTECTION COMMISSIONER	See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	
III	REGISTRATION OF DATA CONTROLLERS AND DATA PROCESSORS	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
III.18	Registration of data controllers and data processors	See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	
III.19	Application for registration	See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	
III.20	Duration of the registration certificate	See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	
III.21	Register of data controllers and data processors	See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	
III.22	Cancellation or variation of the certificate	See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	
III.23	Compliance and audit	The Data Commissioner may carry out periodical audits of the processes and systems of the data controllers or data processors to ensure compliance with this Act.	Functional	No Relationship	N/A	N/A	N/A	0	
III.24	Designation of the Data Protection Officer	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
III.24(1)	Designation of the Data Protection Officer	A data controller or data processor may designate or appoint a data protection officer on such terms and conditions as the data controller or data processor may determine, where —	Functional	Intersects With	Data Protection Officer (DPO)	PRI-01.4	Mechanisms exist to appoint a Data Protection Officer (DPO): (1) Based on professional qualifications; and (2) To be involved in all issues related to how Personal Data (PD) is collected, received, processed, stored, transmitted, shared, updated and/or disposed.	5	
III.24(1)(a)	Designation of the Data Protection Officer	the processing is carried out by a public body or private body, except for courts acting in their judicial capacity;	Functional	Intersects With	Data Protection Officer (DPO)	PRI-01.4	Mechanisms exist to appoint a Data Protection Officer (DPO): (1) Based on professional qualifications; and (2) To be involved in all issues related to how Personal Data (PD) is collected, received, processed, stored, transmitted, shared, updated and/or disposed.	5	
III.24(1)(b)	Designation of the Data Protection Officer	the core activities of the data controller or data processor consist of processing operations which, by virtue of their nature, their scope or their purposes, require regular and systematic monitoring of data subjects; or	Functional	Intersects With	Data Protection Officer (DPO)	PRI-01.4	Mechanisms exist to appoint a Data Protection Officer (DPO): (1) Based on professional qualifications; and (2) To be involved in all issues related to how Personal Data (PD) is collected, received, processed, stored, transmitted, shared, updated and/or disposed.	5	
III.24(1)(c)	Designation of the Data Protection Officer	the core activities of the data controller or the data processor consist of processing of sensitive categories of personal data.	Functional	Intersects With	Data Protection Officer (DPO)	PRI-01.4	Mechanisms exist to appoint a Data Protection Officer (DPO): (1) Based on professional qualifications; and (2) To be involved in all issues related to how Personal Data (PD) is collected, received, processed, stored, transmitted, shared, updated and/or disposed.	5	
III.24(2)	Designation of the Data Protection Officer	A data protection officer may be a staff member of the data controller or data processor and may fulfil other tasks and duties provided that any such tasks and duties do not result in a conflict of interest.	Functional	Intersects With	Data Protection Officer (DPO)	PRI-01.4	Mechanisms exist to appoint a Data Protection Officer (DPO): (1) Based on professional qualifications; and (2) To be involved in all issues related to how Personal Data (PD) is collected, received, processed, stored, transmitted, shared, updated and/or disposed.	5	
III.24(3)	Designation of the Data Protection Officer	A group of entities may appoint a single data protection officer provided that such officer is accessible by each entity.	Functional	Intersects With	Data Protection Officer (DPO)	PRI-01.4	Mechanisms exist to appoint a Data Protection Officer (DPO): (1) Based on professional qualifications; and (2) To be involved in all issues related to how Personal Data (PD) is collected, received, processed, stored, transmitted, shared, updated and/or disposed.	5	
III.24(4)	Designation of the Data Protection Officer	Where a data controller or a data processor is a public body, a single data protection officer may be designated for several such public bodies, taking into account their organisational structures.	Functional	Intersects With	Data Protection Officer (DPO)	PRI-01.4	Mechanisms exist to appoint a Data Protection Officer (DPO): (1) Based on professional qualifications; and (2) To be involved in all issues related to how Personal Data (PD) is collected, received, processed, stored, transmitted, shared, updated and/or disposed.	5	
III.24(5)	Designation of the Data Protection Officer	A person may be designated or appointed as a data protection officer, if that person has relevant academic or professional qualifications which may include knowledge and technical skills in matters relating to data protection.	Functional	Intersects With	Data Protection Officer (DPO)	PRI-01.4	Mechanisms exist to appoint a Data Protection Officer (DPO): (1) Based on professional qualifications; and (2) To be involved in all issues related to how Personal Data (PD) is collected, received, processed, stored, transmitted, shared, updated and/or disposed.	5	
III.24(6)	Designation of the Data Protection Officer	A data controller or data processor shall publish the contact details of the data protection officer on the website and communicate them to the Data Commissioner who shall ensure that the same information is available on the official website.	Functional	Intersects With	Data Protection Officer (DPO)	PRI-01.4	Mechanisms exist to appoint a Data Protection Officer (DPO): (1) Based on professional qualifications; and (2) To be involved in all issues related to how Personal Data (PD) is collected, received, processed, stored, transmitted, shared, updated and/or disposed.	5	
III.24(7)	Designation of the Data Protection Officer	A data protection officer shall —	Functional	Intersects With	Data Protection Officer (DPO)	PRI-01.4	Mechanisms exist to appoint a Data Protection Officer (DPO): (1) Based on professional qualifications; and (2) To be involved in all issues related to how Personal Data (PD) is collected, received, processed, stored, transmitted, shared, updated and/or disposed.	5	
III.24(7)(a)	Designation of the Data Protection Officer	advise the data controller or data processor and their employees on data processing requirements provided under this Act or any other written law;	Functional	Intersects With	Data Protection Officer (DPO)	PRI-01.4	Mechanisms exist to appoint a Data Protection Officer (DPO): (1) Based on professional qualifications; and (2) To be involved in all issues related to how Personal Data (PD) is collected, received, processed, stored, transmitted, shared, updated and/or disposed.	5	
III.24(7)(b)	Designation of the Data Protection Officer	ensure on behalf of the data controller or data processor that this Act is complied with;	Functional	Intersects With	Data Protection Officer (DPO)	PRI-01.4	Mechanisms exist to appoint a Data Protection Officer (DPO): (1) Based on professional qualifications; and (2) To be involved in all issues related to how Personal Data (PD) is collected, received, processed, stored, transmitted, shared, updated and/or disposed.	5	
III.24(7)(c)	Designation of the Data Protection Officer	facilitate capacity building of staff involved in data processing operations;	Functional	Intersects With	Data Protection Officer (DPO)	PRI-01.4	Mechanisms exist to appoint a Data Protection Officer (DPO): (1) Based on professional qualifications; and (2) To be involved in all issues related to how Personal Data (PD) is collected, received, processed, stored, transmitted, shared, updated and/or disposed.	5	
III.24(7)(d)	Designation of the Data Protection Officer	provide advice on data protection impact assessment; and	Functional	Intersects With	Data Protection Officer (DPO)	PRI-01.4	Mechanisms exist to appoint a Data Protection Officer (DPO): (1) Based on professional qualifications; and (2) To be involved in all issues related to how Personal Data (PD) is collected, received, processed, stored, transmitted, shared, updated and/or disposed.	5	
III.24(7)(e)	Designation of the Data Protection Officer	co-operate with the Data Commissioner and any other authority on matters relating to data protection.	Functional	Intersects With	Data Protection Officer (DPO)	PRI-01.4	Mechanisms exist to appoint a Data Protection Officer (DPO): (1) Based on professional qualifications; and (2) To be involved in all issues related to how Personal Data (PD) is collected, received, processed, stored, transmitted, shared, updated and/or disposed.	5	
IV	PRINCIPLES AND OBLIGATIONS OF PERSONAL DATA PROTECTION	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
IV.25	Principles of data protection	Every data controller or data processor shall ensure that personal data is —	Functional	Subset Of	Data Privacy Program	PRI-01	Mechanisms exist to facilitate the implementation and operation of data protection controls throughout the data lifecycle to ensure all forms of Personal Data (PD) are processed lawfully, fairly and transparently.	10	
IV.25(a)	Principles of data protection	processed in accordance with the right to privacy of the data subject;	Functional	Intersects With	Authority To Collect, Process, Store & Share Personal Data (PD)	PRI-04.1	Mechanisms exist to determine and document the legal authority that permits the organization to collect, receive, process, store, transmit, share, update and/or dispose Personal Data (PD), either generally or in support of a specific business process.	8	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
IV.25(a)	Principles of data protection	processed in accordance with the right to privacy of the data subject;	Functional	Intersects With	Usage Restrictions of Personal Data (PD)	PRI-05.4	Mechanisms exist to restrict collecting, receiving, processing, storing, transmitting, sharing and/or updating Personal Data (PD) to: (1) The purpose(s) originally collected, consistent with the data privacy notice(s);	8	
IV.25(b)	Principles of data protection	processed lawfully, fairly and in a transparent manner in relation to any data subject;	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	5	
IV.25(b)	Principles of data protection	processed lawfully, fairly and in a transparent manner in relation to any data subject;	Functional	Intersects With	Usage Restrictions of Personal Data (PD)	PRI-05.4	Mechanisms exist to restrict collecting, receiving, processing, storing, transmitting, sharing and/or updating Personal Data (PD) to: (1) The purpose(s) originally collected, consistent with the data privacy notice(s);	5	
IV.25(c)	Principles of data protection	collected for explicit, specified and legitimate purposes and not further processed in a manner incompatible with those purposes;	Functional	Intersects With	Restrict Collection, Processing & Sharing To Identified Purpose	PRI-04	Mechanisms exist to minimize the collection, processing and/or sharing of Personal Data (PD) to only what is adequate, relevant and limited to the purposes identified in the data privacy notice, including protections against collecting PD from minors without appropriate parental or legal guardian consent.	8	
IV.25(d)	Principles of data protection	adequate, relevant, limited to what is necessary in relation to the purposes for which it is processed;	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	5	
IV.25(e)	Principles of data protection	collected only where a valid explanation is provided whenever information relating to family or private affairs is required;	Functional	Intersects With	Data Privacy Notice	PRI-02	Mechanisms exist to: (1) Make data privacy notice(s) available to individuals upon first interacting with an organization and subsequently as necessary; (2) Ensure that data privacy notices are clear and easy-to-understand;	5	
IV.25(f)	Principles of data protection	accurate and, where necessary, kept up to date, with every reasonable step being taken to ensure that any inaccurate personal data is erased or rectified without delay;	Functional	Intersects With	Personal Data (PD) Accuracy & Integrity	PRI-05.2	Mechanisms exist to ensure the accuracy and relevance of Personal Data (PD) throughout the information lifecycle by: (1) Keeping PD up-to-date; and (2) Remediating identified inaccuracies, as necessary.	8	
IV.25(f)	Principles of data protection	accurate and, where necessary, kept up to date, with every reasonable step being taken to ensure that any inaccurate personal data is erased or rectified without delay;	Functional	Intersects With	Correcting Inaccurate Personal Data (PD)	PRI-06.1	Mechanisms exist to maintain a process for: (1) Data subjects to have inaccurate Personal Data (PD) maintained by the organization corrected or amended; and (2) Disseminating corrections or amendments of PD to other authorized	8	
IV.25(g)	Principles of data protection	kept in a form which identifies the data subjects for no longer than is necessary for the purposes which it was collected; and	Functional	Intersects With	Personal Data (PD) Retention & Disposal	PRI-05	Mechanisms exist to: (1) Retain Personal Data (PD), including metadata, for an organization-defined time period to fulfill the purpose(s) identified in the notice or as required by law; (2) Dispose of, destroys, erases, and/or anonymizes the PD, regardless	8	
IV.25(h)	Principles of data protection	not transferred outside Kenya, unless there is proof of adequate data protection safeguards or consent from the data subject.	Functional	Intersects With	Transfer of Sensitive and/or Regulated Data	DCH-25	Mechanisms exist to restrict and govern the transfer of sensitive and/or regulated data to third-countries or international organizations.	8	
IV.25(h)	Principles of data protection	not transferred outside Kenya, unless there is proof of adequate data protection safeguards or consent from the data subject.	Functional	Intersects With	Binding Corporate Rules (BCR)	PRI-01.5	Mechanisms exist to implement and manage Binding Corporate Rules (BCR) (e.g., data sharing agreement) to legally-bind all parties engaged in a joint economic activity that contractually states enforceable rights	8	
IV.25(h)	Principles of data protection	not transferred outside Kenya, unless there is proof of adequate data protection safeguards or consent from the data subject.	Functional	Intersects With	Information Sharing With Third Parties	PRI-07	Mechanisms exist to disclose Personal Data (PD) to third-parties only for the purposes identified in the data privacy notice and with the implicit or explicit consent of the data subject.	8	
IV.25(h)	Principles of data protection	not transferred outside Kenya, unless there is proof of adequate data protection safeguards or consent from the data subject.	Functional	Intersects With	Data Privacy Requirements for Contractors & Service	PRI-07.1	Mechanisms exist to include data privacy requirements in contracts and other acquisition-related documents that establish data privacy roles and responsibilities for contractors and service providers.	5	
IV.26	Rights of a data subject	A data subject has a right —	Functional	Subset Of	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	10	
IV.26(a)	Rights of a data subject	to be informed of the use to which their personal data is to be put;	Functional	Intersects With	Data Privacy Notice	PRI-02	Mechanisms exist to: (1) Make data privacy notice(s) available to individuals upon first interacting with an organization and subsequently as necessary; (2) Ensure that data privacy notices are clear and easy-to-understand;	8	
IV.26(b)	Rights of a data subject	to access their personal data in custody of data controller or data processor;	Functional	Intersects With	Data Subject Empowerment	PRI-06	Mechanisms exist to provide authenticated data subjects the ability to: (1) Access their Personal Data (PD) that is being processed, stored and shared, except where the burden, risk or expense of providing access would be disproportionate to the benefit offered to the data subject through granting access; (2) Obtain answers on the specifics of how their PD is collected, received, processed, stored, transmitted, shared, updated and/or disposed; (3) Obtain the source(s) of their PD; (4) Obtain the categories of their PD being collected, received, processed, stored and shared; (5) Request correction to their PD due to inaccuracies; (6) Request erasure of their PD; and (7) Restrict the further collecting, receiving, processing, storing, transmitting, updated and/or sharing of their PD.	8	
IV.26(c)	Rights of a data subject	to object to the processing of all or part of their personal data;	Functional	Intersects With	Data Subject Consent	PRI-03	Mechanisms exist to enable data subjects to authorize the collection, receipt, processing, storage, transmission, sharing, updating and/or disposal of their Personal Data (PD), where the data subject is provided, prior to collection, with: (1) Plain language explaining the potential data privacy risks of the authorization; (2) A means to decline the authorization; and (3) Necessary choice and consent-related criteria required by applicable statutory, regulatory and contractual obligations.	8	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
IV.26(c)	Rights of a data subject	to object to the processing of all or part of their personal data;	Functional	Intersects With	Revoke Consent	PRI-03.4	Mechanisms exist to allow data subjects to revoke consent to collect, receive, process, store, transmit, share and/or update their Personal Data (PD).	8	
IV.26(d)	Rights of a data subject	to correction of false or misleading data; and	Functional	Intersects With	Correcting Inaccurate Personal Data (PD)	PRI-06.1	Mechanisms exist to maintain a process for: (1) Data subjects to have inaccurate Personal Data (PD) maintained by the organization corrected or amended; and	8	
IV.26(e)	Rights of a data subject	to deletion of false or misleading data about them.	Functional	Intersects With	Right to Erasure	PRI-06.5	Mechanisms exist to maintain a process to erase a data subject's Personal Data (PD), in accordance with applicable laws, regulations and contractual obligations pertaining to the retention of their PD.	8	
IV.27	Exercise of rights of data subjects	A right conferred on a data subject may be exercised—	Functional	Subset Of	Data Subject Empowerment	PRI-06	Mechanisms exist to provide authenticated data subjects the ability to: (1) Access their Personal Data (PD) that is being processed, stored and shared, except where the burden, risk or expense of providing access would be disproportionate to the benefit offered to the data subject	10	
IV.27(a)	Exercise of rights of data subjects	where the data subject is a minor, by a person who has parental authority or by a guardian;	Functional	Intersects With	Authorized Agent	PRI-03.6	Mechanisms exist to allow data subjects to authorize another person or entity (e.g., authorized agent, proxy, etc.), acting on the data subject's behalf, to make Personal Data (PD) processing decisions.	8	
IV.27(a)	Exercise of rights of data subjects	where the data subject is a minor, by a person who has parental authority or by a guardian;	Functional	Intersects With	Parent or Guardian Opt-In Consent For Minors	PRI-03.13	Mechanisms exist to obtain parental or guardian consent for Personal Data (PD) processing actions through reasonable consumer expectations, when the data subject is a minor.	8	
IV.27(a)	Exercise of rights of data subjects	where the data subject is a minor, by a person who has parental authority or by a guardian;	Functional	Intersects With	Restrict Collection, Processing & Sharing To Identified Purpose	PRI-04	Mechanisms exist to minimize the collection, processing and/or sharing of Personal Data (PD) to only what is adequate, relevant and limited to the purposes identified in the data privacy notice, including	5	
IV.27(b)	Exercise of rights of data subjects	where the data subject has a mental or other disability, by a person duly authorised to act as their guardian or administrator; or	Functional	Intersects With	Authorized Agent	PRI-03.6	Mechanisms exist to allow data subjects to authorize another person or entity (e.g., authorized agent, proxy, etc.), acting on the data subject's behalf, to make Personal Data (PD) processing decisions.	8	
IV.27(c)	Exercise of rights of data subjects	in any other case, by a person duly authorised by the data subject.	Functional	Intersects With	Authorized Agent	PRI-03.6	Mechanisms exist to allow data subjects to authorize another person or entity (e.g., authorized agent, proxy, etc.), acting on the data subject's behalf, to make Personal Data (PD) processing decisions.	8	
IV.28	Collection of personal data	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
IV.28(1)	Collection of personal data	A data controller or data processor shall collect personal data directly from the data subject.	Functional	Intersects With	Active Participation By Data Subjects	PRI-03.7	Mechanisms exist to compel data subjects to select the level of consent deemed appropriate by the data subject for the relevant	3	
IV.28(1)	Collection of personal data	A data controller or data processor shall collect personal data directly from the data subject.	Functional	Intersects With	Primary Sources	PRI-04.2	Mechanisms exist to ensure information is directly collected from the data subject, whenever possible.	8	
IV.28(2)	Collection of personal data	Despite sub-section (1), personal data may be collected indirectly where —	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	5	
IV.28(2)(a)	Collection of personal data	the data is contained in a public record;	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	5	
IV.28(2)(b)	Collection of personal data	the data subject has deliberately made the data public;	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	5	
IV.28(2)(c)	Collection of personal data	the data subject has consented to the collection from another source;	Functional	Intersects With	Data Subject Consent	PRI-03	Mechanisms exist to enable data subjects to authorize the collection, receipt, processing, storage, transmission, sharing, updating and/or disposal of their Personal Data (PD), where the data subject is provided, prior to collection, with:	8	
IV.28(2)(d)	Collection of personal data	the data subject has an incapacity, the guardian appointed has consented to the collection from another source;	Functional	Intersects With	Authorized Agent	PRI-03.6	Mechanisms exist to allow data subjects to authorize another person or entity (e.g., authorized agent, proxy, etc.), acting on the data subject's behalf, to make Personal Data (PD) processing decisions.	5	
IV.28(2)(d)	Collection of personal data	the data subject has an incapacity, the guardian appointed has consented to the collection from another source;	Functional	Intersects With	Parent or Guardian Opt-In Consent For Minors	PRI-03.13	Mechanisms exist to obtain parental or guardian consent for Personal Data (PD) processing actions through reasonable consumer expectations, when the data subject is a minor.	8	
IV.28(2)(e)	Collection of personal data	the collection from another source would not prejudice the interests of the data subject;	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	8	
IV.28(2)(f)	Collection of personal data	collection of data from another source is necessary —	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	5	
IV.28(2)(f)(i)	Collection of personal data	for the prevention, detection, investigation, prosecution and punishment of crime;	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	8	
IV.28(2)(f)(ii)	Collection of personal data	for the enforcement of a law which imposes a pecuniary penalty; or	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	5	
IV.28(2)(f)(iii)	Collection of personal data	for the protection of the interests of the data subject or another person.	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	8	
IV.28(3)	Collection of personal data	A data controller or data processor shall collect, store or use personal data for a purpose which is lawful, specific and explicitly defined.	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	8	
IV.28(3)	Collection of personal data	A data controller or data processor shall collect, store or use personal data for a purpose which is lawful, specific and explicitly defined.	Functional	Intersects With	Authority To Collect, Process, Store & Share Personal Data (PD)	PRI-04.1	Mechanisms exist to determine and document the legal authority that permits the organization to collect, receive, process, store, transmit, share, update and/or dispose Personal Data (PD), either generally or in support of a specific business process.	8	
IV.28(3)	Collection of personal data	A data controller or data processor shall collect, store or use personal data for a purpose which is lawful, specific and explicitly defined.	Functional	Intersects With	Usage Restrictions of Personal Data (PD)	PRI-05.4	Mechanisms exist to restrict collecting, receiving, processing, storing, transmitting, sharing and/or updating Personal Data (PD) to: (1) The purpose(s) originally collected, consistent with the data privacy notice(s);	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
IV.29	Duty to notify	A data controller or data processor shall, before collecting personal data, in so far as practicable, inform the data subject of —	Functional	Subset Of	Data Privacy Notice	PRI-02	Mechanisms exist to: (1) Make data privacy notice(s) available to individuals upon first interacting with an organization and subsequently as necessary; (2) Ensure that data privacy notices are clear and easy-to-understand, expressing relevant information about how Personal Data (PD) is collected, received, processed, stored, transmitted, shared, updated and/or disposed;	10	
IV.29(a)	Duty to notify	the rights of data subject specified under section 26;	Functional	Subset Of	Data Privacy Notice	PRI-02	Mechanisms exist to: (1) Make data privacy notice(s) available to individuals upon first interacting with an organization and subsequently as necessary; (2) Ensure that data privacy notices are clear and easy-to-understand, expressing relevant information about how Personal Data (PD) is collected, received, processed, stored, transmitted, shared, updated and/or disposed; (3) Contain all necessary notice-related criteria required by applicable statutory, regulatory and contractual obligations; (4) Define the scope of PD processing activities, including the geographic locations and third-party recipients that process the PD within the scope of the data privacy notice; (5) Periodically, review and update the content of the privacy notice, as necessary; and (6) Retain prior versions of the privacy notice, in accordance with data retention requirements.	10	
IV.29(b)	Duty to notify	the fact that personal data is being collected;	Functional	Subset Of	Data Privacy Notice	PRI-02	Mechanisms exist to: (1) Make data privacy notice(s) available to individuals upon first interacting with an organization and subsequently as necessary; (2) Ensure that data privacy notices are clear and easy-to-understand, expressing relevant information about how Personal Data (PD) is collected, received, processed, stored, transmitted, shared, updated and/or disposed; (3) Contain all necessary notice-related criteria required by applicable statutory, regulatory and contractual obligations; (4) Define the scope of PD processing activities, including the geographic locations and third-party recipients that process the PD within the scope of the data privacy notice; (5) Periodically, review and update the content of the privacy notice, as necessary; and (6) Retain prior versions of the privacy notice, in accordance with data retention requirements.	10	
IV.29(c)	Duty to notify	the purpose for which the personal data is being collected;	Functional	Subset Of	Data Privacy Notice	PRI-02	Mechanisms exist to: (1) Make data privacy notice(s) available to individuals upon first interacting with an organization and subsequently as necessary; (2) Ensure that data privacy notices are clear and easy-to-understand, expressing relevant information about how Personal Data (PD) is collected, received, processed, stored, transmitted, shared, updated and/or disposed; (3) Contain all necessary notice-related criteria required by applicable statutory, regulatory and contractual obligations; (4) Define the scope of PD processing activities, including the geographic locations and third-party recipients that process the PD within the scope of the data privacy notice; (5) Periodically, review and update the content of the privacy notice, as necessary; and (6) Retain prior versions of the privacy notice, in accordance with data retention requirements.	10	
IV.29(d)	Duty to notify	the third parties whose personal data has been or will be transferred to, including details of safeguards adopted;	Functional	Subset Of	Data Privacy Notice	PRI-02	Mechanisms exist to: (1) Make data privacy notice(s) available to individuals upon first interacting with an organization and subsequently as necessary; (2) Ensure that data privacy notices are clear and easy-to-understand, expressing relevant information about how Personal Data (PD) is collected, received, processed, stored, transmitted, shared, updated and/or disposed; (3) Contain all necessary notice-related criteria required by applicable statutory, regulatory and contractual obligations; (4) Define the scope of PD processing activities, including the geographic locations and third-party recipients that process the PD within the scope of the data privacy notice; (5) Periodically, review and update the content of the privacy notice, as necessary; and (6) Retain prior versions of the privacy notice, in accordance with data retention requirements.	10	
IV.29(e)	Duty to notify	the contacts of the data controller or data processor and on whether any other entity may receive the collected personal data;	Functional	Subset Of	Data Privacy Notice	PRI-02	Mechanisms exist to: (1) Make data privacy notice(s) available to individuals upon first interacting with an organization and subsequently as necessary; (2) Ensure that data privacy notices are clear and easy-to-understand, expressing relevant information about how Personal Data (PD) is collected, received, processed, stored, transmitted, shared, updated and/or disposed; (3) Contain all necessary notice-related criteria required by applicable statutory, regulatory and contractual obligations; (4) Define the scope of PD processing activities, including the geographic locations and third-party recipients that process the PD within the scope of the data privacy notice; (5) Periodically, review and update the content of the privacy notice, as necessary; and (6) Retain prior versions of the privacy notice, in accordance with data retention requirements.	10	
IV.29(f)	Duty to notify	a description of the technical and organizational security measures taken to ensure the integrity and confidentiality of the data;	Functional	Subset Of	Data Privacy Notice	PRI-02	Mechanisms exist to: (1) Make data privacy notice(s) available to individuals upon first interacting with an organization and subsequently as necessary; (2) Ensure that data privacy notices are clear and easy-to-understand, expressing relevant information about how Personal Data (PD) is collected, received, processed, stored, transmitted, shared, updated and/or disposed; (3) Contain all necessary notice-related criteria required by applicable statutory, regulatory and contractual obligations; (4) Define the scope of PD processing activities, including the geographic locations and third-party recipients that process the PD within the scope of the data privacy notice; (5) Periodically, review and update the content of the privacy notice, as necessary; and (6) Retain prior versions of the privacy notice, in accordance with data retention requirements.	10	
IV.29(g)	Duty to notify	the data being collected pursuant to any law and whether such collection is voluntary or mandatory; and	Functional	Subset Of	Data Privacy Notice	PRI-02	Mechanisms exist to: (1) Make data privacy notice(s) available to individuals upon first interacting with an organization and subsequently as necessary; (2) Ensure that data privacy notices are clear and easy-to-understand, expressing relevant information about how Personal Data (PD) is collected, received, processed, stored, transmitted, shared, updated and/or disposed; (3) Contain all necessary notice-related criteria required by applicable statutory, regulatory and contractual obligations; (4) Define the scope of PD processing activities, including the geographic locations and third-party recipients that process the PD within the scope of the data privacy notice; (5) Periodically, review and update the content of the privacy notice, as necessary; and (6) Retain prior versions of the privacy notice, in accordance with data retention requirements.	10	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
IV.29(h)	Duty to notify	the consequences if any, where the data subject fails to provide all or any part of the requested data.	Functional	Subset Of	Data Privacy Notice	PRI-02	Mechanisms exist to: (1) Make data privacy notice(s) available to individuals upon first interacting with an organization and subsequently as necessary; (2) Ensure that data privacy notices are clear and easy-to-understand, expressing relevant information about how Personal Data (PD) is collected, received, processed, stored, transmitted, shared, updated and/or disposed; (3) Contain all necessary notice-related criteria required by applicable statutory, regulatory and contractual obligations; (4) Define the scope of PD processing activities, including the geographic locations and third-party recipients that process the PD within the scope of the data privacy notice; (5) Periodically, review and update the content of the privacy notice, as necessary; and (6) Retain prior versions of the privacy notice, in accordance with data retention requirements.	10	
IV.30	Lawful processing of personal data	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
IV.30(1)	Lawful processing of personal data	A data controller or data processor shall not process personal data, unless —	Functional	Subset Of	Usage Restrictions of Personal Data (PD)	PRI-05.4	Mechanisms exist to restrict collecting, receiving, processing, storing, transmitting, sharing and/or updating Personal Data (PD) to:	10	
IV.30(1)(a)	Lawful processing of personal data	the data subject consents to the processing for one or more specified purposes; or	Functional	Subset Of	Usage Restrictions of Personal Data (PD)	PRI-05.4	Mechanisms exist to restrict collecting, receiving, processing, storing, transmitting, sharing and/or updating Personal Data (PD) to: (1) The purpose(s) originally collected, consistent with the data privacy notice(s); (2) What is authorized by the data subject, or authorized agent; and (3) What is consistent with applicable laws, regulations and contractual obligations.	10	
IV.30(1)(b)	Lawful processing of personal data	the processing is necessary —	Functional	Subset Of	Usage Restrictions of Personal Data (PD)	PRI-05.4	Mechanisms exist to restrict collecting, receiving, processing, storing, transmitting, sharing and/or updating Personal Data (PD) to: (1) The purpose(s) originally collected, consistent with the data privacy notice(s); (2) What is authorized by the data subject, or authorized agent; and (3) What is consistent with applicable laws, regulations and contractual obligations.	10	
IV.30(1)(b)(i)	Lawful processing of personal data	for the performance of a contract to which the data subject is a party or in order to take steps at the request of the data subject before entering into a contract;	Functional	Subset Of	Usage Restrictions of Personal Data (PD)	PRI-05.4	Mechanisms exist to restrict collecting, receiving, processing, storing, transmitting, sharing and/or updating Personal Data (PD) to: (1) The purpose(s) originally collected, consistent with the data privacy notice(s); (2) What is authorized by the data subject, or authorized agent; and (3) What is consistent with applicable laws, regulations and contractual obligations.	10	
IV.30(1)(b)(ii)	Lawful processing of personal data	for compliance with any legal obligation to which the controller is subject;	Functional	Subset Of	Usage Restrictions of Personal Data (PD)	PRI-05.4	Mechanisms exist to restrict collecting, receiving, processing, storing, transmitting, sharing and/or updating Personal Data (PD) to: (1) The purpose(s) originally collected, consistent with the data privacy notice(s); (2) What is authorized by the data subject, or authorized agent; and (3) What is consistent with applicable laws, regulations and contractual obligations.	10	
IV.30(1)(b)(iii)	Lawful processing of personal data	in order to protect the vital interests of the data subject or another natural person;	Functional	Subset Of	Usage Restrictions of Personal Data (PD)	PRI-05.4	Mechanisms exist to restrict collecting, receiving, processing, storing, transmitting, sharing and/or updating Personal Data (PD) to: (1) The purpose(s) originally collected, consistent with the data privacy notice(s); (2) What is authorized by the data subject, or authorized agent; and (3) What is consistent with applicable laws, regulations and contractual obligations.	10	
IV.30(1)(b)(iv)	Lawful processing of personal data	for the performance of a task carried out in the public interest or in the exercise of official authority vested in the controller;	Functional	Subset Of	Usage Restrictions of Personal Data (PD)	PRI-05.4	Mechanisms exist to restrict collecting, receiving, processing, storing, transmitting, sharing and/or updating Personal Data (PD) to: (1) The purpose(s) originally collected, consistent with the data privacy notice(s); (2) What is authorized by the data subject, or authorized agent; and (3) What is consistent with applicable laws, regulations and contractual obligations.	10	
IV.30(1)(b)(v)	Lawful processing of personal data	the performance of any task carried out by a public authority;	Functional	Subset Of	Usage Restrictions of Personal Data (PD)	PRI-05.4	Mechanisms exist to restrict collecting, receiving, processing, storing, transmitting, sharing and/or updating Personal Data (PD) to: (1) The purpose(s) originally collected, consistent with the data privacy notice(s); (2) What is authorized by the data subject, or authorized agent; and (3) What is consistent with applicable laws, regulations and contractual obligations.	10	
IV.30(1)(b)(vi)	Lawful processing of personal data	for the exercise, by any person in the public interest, of any other functions of a public nature;	Functional	Subset Of	Usage Restrictions of Personal Data (PD)	PRI-05.4	Mechanisms exist to restrict collecting, receiving, processing, storing, transmitting, sharing and/or updating Personal Data (PD) to: (1) The purpose(s) originally collected, consistent with the data privacy notice(s); (2) What is authorized by the data subject, or authorized agent; and (3) What is consistent with applicable laws, regulations and contractual obligations.	10	
IV.30(1)(b)(vii)	Lawful processing of personal data	for the legitimate interests pursued by the data controller or data processor by a third party to whom the data is disclosed, except if the processing is unwarranted in any particular case having regard to the harm and prejudice to the rights and freedoms or legitimate interests of the data subject; or	Functional	Subset Of	Usage Restrictions of Personal Data (PD)	PRI-05.4	Mechanisms exist to restrict collecting, receiving, processing, storing, transmitting, sharing and/or updating Personal Data (PD) to: (1) The purpose(s) originally collected, consistent with the data privacy notice(s); (2) What is authorized by the data subject, or authorized agent; and (3) What is consistent with applicable laws, regulations and contractual obligations.	10	
IV.30(1)(b)(viii)	Lawful processing of personal data	for the purpose of historical, statistical, journalistic, literature and art or scientific research.	Functional	Subset Of	Internal Use of Personal Data (PD) For Testing, Training and Research	PRI-05.1	Mechanisms exist to address the use of Personal Data (PD) for internal testing, training and research that: (1) Takes measures to limit or minimize the amount of PD used for internal testing, training and research purposes; and (2) Authorizes the use of PD when such information is required for internal testing, training and research.	10	
IV.30(2)	Lawful processing of personal data	Further processing of personal data shall be in accordance with the purpose of collection.	Functional	Subset Of	Usage Restrictions of Personal Data (PD)	PRI-05.4	Mechanisms exist to restrict collecting, receiving, processing, storing, transmitting, sharing and/or updating Personal Data (PD) to: (1) The purpose(s) originally collected, consistent with the data privacy notice(s); (2) What is authorized by the data subject, or authorized agent; and (3) What is consistent with applicable laws, regulations and	10	
IV.30(3)	Lawful processing of personal data	A data controller who contravenes the provisions of sub-section (1) commits an offence.	Functional	No Relationship	N/A	N/A	N/A	0	
IV.31	Data protection impact	N/A	Functional	No Relationship	N/A	N/A	N/A	0	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Document: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **Kenya - Data Protection Act (DPA) (2019)**

Focal Document URL: http://kenyalaw.org/kl/fileadmin/pdfdownloads/Acts/2019/TheDataProtectionAct_No24of2019.pdf

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-emea-ken-pda-2019.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
IV.31(1)	Data protection impact assessment	Where a processing operation is likely to result in high risk to the rights and freedoms of a data subject, by virtue of its nature, scope, context and purposes, a data controller or data processor shall, prior to the processing, A data protection impact assessment shall include the following —	Functional	Subset Of	Data Protection Impact Assessment (DPIA)	RSK-10	Mechanisms exist to conduct a Data Protection Impact Assessment (DPIA) on Technology Assets, Applications and/or Services (TAAS) that store, process and/or transmit Personal Data (PD) to identify and	10	
IV.31(2)	Data protection impact assessment	A data protection impact assessment shall include the following —	Functional	Subset Of	Data Protection Impact Assessment (DPIA)	RSK-10	Mechanisms exist to conduct a Data Protection Impact Assessment (DPIA) on Technology Assets, Applications and/or Services (TAAS) that store, process and/or transmit Personal Data (PD) to identify and remediate reasonably-expected risks.	10	
IV.31(2)(a)	Data protection impact assessment	a systematic description of the envisaged processing operations and the purposes of the processing, including, where applicable, the legitimate interest pursued by the data controller or data processor;	Functional	Subset Of	Data Protection Impact Assessment (DPIA)	RSK-10	Mechanisms exist to conduct a Data Protection Impact Assessment (DPIA) on Technology Assets, Applications and/or Services (TAAS) that store, process and/or transmit Personal Data (PD) to identify and remediate reasonably-expected risks.	10	
IV.31(2)(b)	Data protection impact assessment	an assessment of the necessity and proportionality of the processing operations in relation to the purposes;	Functional	Subset Of	Data Protection Impact Assessment (DPIA)	RSK-10	Mechanisms exist to conduct a Data Protection Impact Assessment (DPIA) on Technology Assets, Applications and/or Services (TAAS) that store, process and/or transmit Personal Data (PD) to identify and remediate reasonably-expected risks.	10	
IV.31(2)(c)	Data protection impact assessment	an assessment of the risks to the rights and freedoms of data subjects;	Functional	Subset Of	Data Protection Impact Assessment (DPIA)	RSK-10	Mechanisms exist to conduct a Data Protection Impact Assessment (DPIA) on Technology Assets, Applications and/or Services (TAAS) that store, process and/or transmit Personal Data (PD) to identify and remediate reasonably-expected risks.	10	
IV.31(2)(d)	Data protection impact assessment	the measures envisaged to address the risks and the safeguards, security measures and mechanisms to ensure the protection of personal data and to demonstrate compliance with this Act, taking into account the rights, and legitimate interests of data subjects and other persons concerned.	Functional	Subset Of	Data Protection Impact Assessment (DPIA)	RSK-10	Mechanisms exist to conduct a Data Protection Impact Assessment (DPIA) on Technology Assets, Applications and/or Services (TAAS) that store, process and/or transmit Personal Data (PD) to identify and remediate reasonably-expected risks.	10	
IV.31(3)	Data protection impact assessment	The data controller or data processor shall consult the Data Commissioner prior to the processing if a data protection impact assessment prepared under this section indicates that the processing of the data would result in a high risk to the rights and freedoms of a data subject.	Functional	Subset Of	Data Protection Impact Assessment (DPIA)	RSK-10	Mechanisms exist to conduct a Data Protection Impact Assessment (DPIA) on Technology Assets, Applications and/or Services (TAAS) that store, process and/or transmit Personal Data (PD) to identify and remediate reasonably-expected risks.	10	
IV.31(4)	Data protection impact assessment	For the purposes of this section, a "data protection impact assessment" means an assessment of the impact of the envisaged processing operations on the protection of personal data.	Functional	No Relationship	N/A	N/A	N/A	0	
IV.31(5)	Data protection impact assessment	The data impact assessment reports shall be submitted sixty days prior to the processing of data.	Functional	Intersects With	Security, Compliance & Resilience Status Reporting	GOV-17	Mechanisms exist to submit status reporting of the organization's security, compliance and/or resilience program to applicable statutory and/or regulatory authorities, as required.	8	
IV.31(6)	Data protection impact assessment	The Data Commissioner shall set out guidelines for carrying out an impact assessment under this section.	Functional	No Relationship	N/A	N/A	N/A	0	
IV.32	Conditions of consent	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
IV.32(1)	Conditions of consent	A data controller or data processor shall bear the burden of proof for establishing a data subject's consent to the processing of their personal	Functional	Intersects With	Ability To Demonstrate Conformity	CPL-01.3	Mechanisms exist to ensure the organization is able to demonstrate security, compliance and/or resilience capability conformity with	8	
IV.32(2)	Conditions of consent	Unless otherwise provided under this Act, a data subject shall have the right to withdraw consent at any time.	Functional	Intersects With	Revoke Consent	PRI-03.4	Mechanisms exist to allow data subjects to revoke consent to collect, receive, process, store, transmit, share and/or update their Personal Data (PD).	8	
IV.32(3)	Conditions of consent	The withdrawal of consent under sub-section (2) shall not affect the lawfulness of processing based on prior consent before its withdrawal.	Functional	Intersects With	Revoke Consent	PRI-03.4	Mechanisms exist to allow data subjects to revoke consent to collect, receive, process, store, transmit, share and/or update their Personal Data (PD).	8	
IV.32(4)	Conditions of consent	In determining whether consent was freely given, account shall be taken of whether, among others, the performance of a contract, including the provision of a service, is conditional on consent to the processing of	Functional	Intersects With	Data Subject Consent	PRI-03	Mechanisms exist to enable data subjects to authorize the collection, receipt, processing, storage, transmission, sharing, updating and/or disposal of their Personal Data (PD), where the data subject is	8	
IV.32(4)	Conditions of consent	In determining whether consent was freely given, account shall be taken of whether, among others, the performance of a contract, including the provision of a service, is conditional on consent to the processing of personal data that is not necessary for the performance of that contract.	Functional	Intersects With	Product or Service Delivery Restrictions	PRI-03.5	Mechanisms exist to prevent discrimination against a data subject for exercising their legal rights pertaining to modifying or revoking consent, including prohibiting: (1) Refusing products and/or services; (2) Charging different rates for goods and/or services; and (3) Providing different levels of quality.	3	
IV.33	Processing of personal data relating to a child	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
IV.33(1)	Processing of personal data relating to a child	Every data controller or data processor shall not process personal data relating to a child unless —	Functional	Subset Of	Usage Restrictions of Personal Data (PD)	PRI-05.4	Mechanisms exist to restrict collecting, receiving, processing, storing, transmitting, sharing and/or updating Personal Data (PD) to:	10	
IV.33(1)(a)	Processing of personal data relating to a child	consent is given by the child's parent or guardian; and	Functional	Subset Of	Usage Restrictions of Personal Data (PD)	PRI-05.4	(1) The purpose(s) originally collected, consistent with the data privacy notice(s); (2) What is authorized by the data subject, or authorized agent; and (3) What is consistent with applicable laws, regulations and contractual obligations.	10	
IV.33(1)(b)	Processing of personal data relating to a child	the processing is in such a manner that protects and advances the rights and best interests of the child.	Functional	Subset Of	Usage Restrictions of Personal Data (PD)	PRI-05.4	Mechanisms exist to restrict collecting, receiving, processing, storing, transmitting, sharing and/or updating Personal Data (PD) to:	10	
IV.33(2)	Processing of personal data relating to a child	A data controller or data processor shall incorporate appropriate mechanisms for age verification and consent in order to process personal data of a child.	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	8	
IV.33(2)	Processing of personal data relating to a child	A data controller or data processor shall incorporate appropriate mechanisms for age verification and consent in order to process personal data of a child.	Functional	Intersects With	Parent or Guardian Opt-In Consent For Minors	PRI-03.13	Mechanisms exist to obtain parental or guardian consent for Personal Data (PD) processing actions through reasonable consumer expectations, when the data subject is a minor.	8	
IV.33(3)	Processing of personal data relating to a child	Mechanisms contemplated under sub-section (2) shall be determined on the basis of—	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary.	5	
IV.33(3)(a)	Processing of personal data relating to a child	available technology;	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	5	
IV.33(3)(b)	Processing of personal data relating to a child	volume of personal data processed;	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	5	
IV.33(3)(c)	Processing of personal data relating to a child	proportion of such personal data likely to be that of a child;	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	5	
IV.33(3)(d)	Processing of personal data relating to a child	possibility of harm to a child arising out of processing of personal data; and	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	5	
IV.33(3)(e)	Processing of personal data relating to a child	such other factors as may be specified by the Data Commissioner.	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
IV.33(4)	Processing of personal data relating to a child	A data controller or data processor that exclusively provides counselling or child protection services to a child may not be required to obtain parental consent as set out under sub-section (1).	Functional	Intersects With	Parent or Guardian Opt-In Consent For Minors	PRI-03.13	Mechanisms exist to obtain parental or guardian consent for Personal Data (PD) processing actions through reasonable consumer expectations, when the data subject is a minor.	5	
IV.34	Restrictions on processing	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
IV.34(1)	Restrictions on processing	A data controller or data processor shall, at the request of a data subject, restrict the processing of personal data where— accuracy of the personal data is contested by the data subject, for a period enabling the data controller to verify the accuracy of the data;	Functional	Subset Of	Data Subject Empowerment	PRI-06	Mechanisms exist to provide authenticated data subjects the ability to: (1) Access their Personal Data (PD) that is being processed, stored and	10	
IV.34(1)(a)	Restrictions on processing		Functional	Intersects With	Correcting Inaccurate Personal Data (PD)	PRI-06.1	Mechanisms exist to maintain a process for: (1) Data subjects to have inaccurate Personal Data (PD) maintained by the organization corrected or amended; and (2) Disseminating corrections or amendments of PD to other authorized users of the PD.	5	
IV.34(1)(b)	Restrictions on processing	personal data is no longer required for the purpose of the processing, unless the data controller or data processor requires the personal data for the establishment, exercise or defence of a legal claim;	Functional	Intersects With	Personal Data (PD) Retention & Disposal	PRI-05	Mechanisms exist to: (1) Retain Personal Data (PD), including metadata, for an organization-defined time period to fulfill the purpose(s) identified in the notice or as required by law; (2) Dispose of, destroys, erases, and/or anonymizes the PD, regardless	5	
IV.34(1)(c)	Restrictions on processing	processing is unlawful and the data subject opposes the erasure of the personal data and requests the restriction of their use instead; or	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	5	
IV.34(1)(d)	Restrictions on processing	data subject has objected to the processing, pending verification as to whether the legitimate interests of the data controller or data processor overrides those of the data subject.	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	5	
IV.34(2)	Restrictions on processing	Where processing of personal data is restricted under this section—	Functional	No Relationship	N/A	N/A	N/A	0	
IV.34(2)(a)	Restrictions on processing	the personal data shall, unless the data is being stored, only be processed with the data subject's consent or for the establishment, exercise or	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD)	5	
IV.34(2)(b)	Restrictions on processing	the data controller shall inform the data subject before withdrawing the restriction on processing of the personal data.	Functional	Intersects With	Data Subject Communications	PRI-17	Mechanisms exist to craft disclosures and communications to data subjects in a manner that is concise, unambiguous and understandable by a reasonable person.	3	
IV.34(3)	Restrictions on processing	The data controller or data processor shall implement mechanisms to ensure that time limits established for the rectification, erasure or restriction of processing of personal data, or for a periodic review of the	Functional	Intersects With	Personal Data (PD) Retention & Disposal	PRI-05	Mechanisms exist to: (1) Retain Personal Data (PD), including metadata, for an organization-defined time period to fulfill the purpose(s) identified in the notice or as	8	
IV.35	Automated individual decision making	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
IV.35(1)	Automated individual decision making	Every data subject has a right not to be subject to a decision based solely on automated processing, including profiling, which produces legal effects concerning or significantly affects the data subject.	Functional	Intersects With	Automated Data Management Processes	PRI-02.2	Automated mechanisms exist to adjust data that is able to be collected, received, processed, stored, transmitted, shared, updated and/or disposed, based on updated data subject authorization(s).	5	
IV.35(1)	Automated individual decision making	Every data subject has a right not to be subject to a decision based solely on automated processing, including profiling, which produces legal effects concerning or significantly affects the data subject.	Functional	Intersects With	Automated Decision-Making Technology (ADMT) For Data Subject Actions	PRI-19	Mechanisms exist to ensure data subject actions utilizing Automated Decision-Making Technology (ADMT) where computation replaces, or substantially replaces, human decisionmaking, conforms with all applicable statutory, regulatory and/or contractual obligations.	8	
IV.35(1)	Automated individual decision making	Every data subject has a right not to be subject to a decision based solely on automated processing, including profiling, which produces legal effects concerning or significantly affects the data subject.	Functional	Intersects With	Automated Decision-Making Technology (ADMT) Opt-Out Consent	PRI-19.2	Mechanisms exist to provide concise, unambiguous and understandable instructions on how data subjects can opt-out of Automated Decision-Making Technology (ADMT).	8	
IV.35(2)	Automated individual decision making	Sub-section (1) shall not apply where the decision is -	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	5	
IV.35(2)(a)	Automated individual decision making	necessary for entering into, or performing, a contract between the data subject and a data controller;	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	5	
IV.35(2)(b)	Automated individual decision making	authorised by a law to which the data controller is subject and which lays down suitable measures to safeguard the data subject's rights, freedoms and legitimate interests; or	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	5	
IV.35(2)(c)	Automated individual decision making	based on the data subject's consent.	Functional	Intersects With	Reasonable Data Privacy Practices	PRI-01.11	Mechanisms exist to limit the collection, receiving, processing, storage, transmission, sharing, updating and/or disposal of Personal Data (PD) according to reasonable consumer expectations for what is necessary and proportionate.	5	
IV.35(3)	Automated individual decision making	Where a data controller or data processor takes a decision, which produces legal effects or significantly affects the data subject based solely on automated processing—	Functional	No Relationship	N/A	N/A	N/A	0	
IV.35(3)(a)	Automated individual decision making	the data controller or data processor must, as soon as reasonably practicable, notify the data subject in writing that a decision has been taken based solely on automated processing; and	Functional	Intersects With	Automated Decision-Making Technology (ADMT) Use Notification	PRI-19.1	Mechanisms exist to notify data subjects of their rights through a pre-use notice when their Personal Data (PD) will be processed by an Automated Decision-Making Technology (ADMT).	5	
IV.35(3)(a)	Automated individual decision making	the data controller or data processor must, as soon as reasonably practicable, notify the data subject in writing that a decision has been taken based solely on automated processing; and	Functional	Intersects With	Data Subject Communications	PRI-17	Mechanisms exist to craft disclosures and communications to data subjects in a manner that is concise, unambiguous and understandable by a reasonable person.	8	
IV.35(3)(b)	Automated individual decision making	the data subject may, after a reasonable period of receipt of the notification, request the data controller or data processor to —	Functional	No Relationship	N/A	N/A	N/A	0	
IV.35(3)(b)(i)	Automated individual decision making	reconsider the decision; or	Functional	Intersects With	Data Subject Empowerment	PRI-06	Mechanisms exist to provide authenticated data subjects the ability to: (1) Access their Personal Data (PD) that is being processed, stored and shared, except where the burden, risk or expense of providing access	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
IV.35(3)(b)(ii)	Automated individual decision making	take a new decision that is not based solely on automated processing.	Functional	Intersects With	Data Subject Empowerment	PRI-06	Mechanisms exist to provide authenticated data subjects the ability to: (1) Access their Personal Data (PD) that is being processed, stored and shared, except where the burden, risk or expense of providing access would be disproportionate to the benefit offered to the data subject through granting access; (2) Obtain answers on the specifics of how their PD is collected, received, processed, stored, transmitted, shared, updated and/or disposed; (3) Obtain the source(s) of their PD; (4) Obtain the categories of their PD being collected, received, processed, stored and shared; (5) Request correction to their PD due to inaccuracies; (6) Request erasure of their PD; and (7) Restrict the further collecting, receiving, processing, storing, transmitting, updated and/or sharing of their PD.	5	
IV.35(4)	Automated individual decision making	A data controller or data processor, upon receipt of a request under sub-section (3), shall within a reasonable period of time —	Functional	No Relationship	N/A	N/A	N/A	0	
IV.35(4)(a)	Automated individual decision making	consider the request, including any information provided by the data subject that is relevant to it;	Functional	Intersects With	Data Subject Feedback Management	PRI-06.4	Mechanisms exist to maintain a process to efficiently and effectively respond to requests, complaints, concerns and/or questions from authenticated data subjects about Personal Data (PD) the organization	3	
IV.35(4)(b)	Automated individual decision making	comply with the request; and	Functional	Intersects With	Data Subject Feedback Management	PRI-06.4	Mechanisms exist to maintain a process to efficiently and effectively respond to requests, complaints, concerns and/or questions from authenticated data subjects about Personal Data (PD) the organization collects, receives, processes, stores, transmits, shares, updates and/or disposes.	3	
IV.35(4)(c)	Automated individual decision making	by notice in writing inform the data subject of —	Functional	Intersects With	Data Subject Feedback Management	PRI-06.4	Mechanisms exist to maintain a process to efficiently and effectively respond to requests, complaints, concerns and/or questions from authenticated data subjects about Personal Data (PD) the organization collects, receives, processes, stores, transmits, shares, updates and/or disposes.	5	
IV.35(4)(c)(i)	Automated individual decision making	the steps taken to comply with the request; and	Functional	Intersects With	Data Subject Feedback Management	PRI-06.4	Mechanisms exist to maintain a process to efficiently and effectively respond to requests, complaints, concerns and/or questions from authenticated data subjects about Personal Data (PD) the organization collects, receives, processes, stores, transmits, shares, updates and/or disposes.	3	
IV.35(4)(c)(ii)	Automated individual decision making	the outcome of complying with the request.	Functional	Intersects With	Data Subject Feedback Management	PRI-06.4	Mechanisms exist to maintain a process to efficiently and effectively respond to requests, complaints, concerns and/or questions from authenticated data subjects about Personal Data (PD) the organization collects, receives, processes, stores, transmits, shares, updates and/or disposes.	3	
IV.35(5)	Automated individual decision making	The Cabinet Secretary may by Regulations make such further provision to provide suitable measures to safeguard a data subject's rights, freedoms and legitimate interests in connection with the taking of decisions based solely on automated processing.	Functional	No Relationship	N/A	N/A	N/A	0	
IV.36	Objecting to processing	A data subject has a right to object to the processing of their personal data, unless the data controller or data processor demonstrates compelling legitimate interest for the processing which overrides the data subject's interests, or for the establishment, exercise or defence of a legal claim.	Functional	Intersects With	Prohibition of Selling, Processing and/or Sharing Personal Data (PD)	PRI-03.3	Mechanisms exist to prevent the sale, processing and/or sharing of Personal Data (PD) when: (1) Instructed by the data subject; or (2) The data subject is a minor, where selling and/or sharing PD is	5	
IV.36	Objecting to processing	A data subject has a right to object to the processing of their personal data, unless the data controller or data processor demonstrates compelling legitimate interest for the processing which overrides the data subject's interests, or for the establishment, exercise or defence of a legal claim.	Functional	Intersects With	Usage Restrictions of Personal Data (PD)	PRI-05.4	Mechanisms exist to restrict collecting, receiving, processing, storing, transmitting, sharing and/or updating Personal Data (PD) to: (1) The purpose(s) originally collected, consistent with the data privacy notice(s); (2) What is authorized by the data subject, or authorized agent; and	5	
IV.37	Commercial use of data	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
IV.37(1)	Commercial use of data	A person shall not use, for commercial purposes, personal data obtained pursuant to the provisions of this Act unless the person —	Functional	Subset Of	Statutory, Regulatory & Contractual Compliance	CPL-01	Mechanisms exist to facilitate the identification and implementation of relevant statutory, regulatory and contractual controls.	10	
IV.37(1)(a)	Commercial use of data	has sought and obtained express consent from a data subject; or	Functional	Subset Of	Statutory, Regulatory & Contractual Compliance	CPL-01	Mechanisms exist to facilitate the identification and implementation of relevant statutory, regulatory and contractual controls.	10	
IV.37(1)(b)	Commercial use of data	is authorised to do so under any written law and the data subject has been informed of such use when collecting the data from the data subject.	Functional	Subset Of	Statutory, Regulatory & Contractual Compliance	CPL-01	Mechanisms exist to facilitate the identification and implementation of relevant statutory, regulatory and contractual controls.	10	
IV.37(2)	Commercial use of data	A data controller or data processor that uses personal data for commercial purposes shall, where possible, anonymise the data in such a manner as to ensure that the data subject is no longer identifiable.	Functional	Subset Of	Statutory, Regulatory & Contractual Compliance	CPL-01	Mechanisms exist to facilitate the identification and implementation of relevant statutory, regulatory and contractual controls.	10	
IV.37(3)	Commercial use of data	The Cabinet Secretary, in consultation with the Data Commissioner, may prescribe practice guidelines for commercial use of personal data in accordance with this Act.	Functional	Subset Of	Statutory, Regulatory & Contractual Compliance	CPL-01	Mechanisms exist to facilitate the identification and implementation of relevant statutory, regulatory and contractual controls.	10	
IV.38	Right to data portability	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
IV.38(1)	Right to data portability	A data subject has the right to receive personal data concerning them in a structured, commonly used and machine-readable format.	Functional	Intersects With	Data Subject Empowerment	PRI-06	Mechanisms exist to provide authenticated data subjects the ability to: (1) Access their Personal Data (PD) that is being processed, stored and	8	
IV.38(1)	Right to data portability	A data subject has the right to receive personal data concerning them in a structured, commonly used and machine-readable format.	Functional	Intersects With	Data Portability	PRI-06.6	Mechanisms exist to format exports of Personal Data (PD) in a structured, machine-readable format that allows data subjects to transfer their PD to another controller without hindrance.	8	
IV.38(1)	Right to data portability	A data subject has the right to receive personal data concerning them in a structured, commonly used and machine-readable format.	Functional	Intersects With	Personal Data (PD) Exports	PRI-06.7	Mechanisms exist to export a data subject's available Personal Data (PD) in a readily usable format, upon an authenticated request.	5	
IV.38(2)	Right to data portability	A data subject has the right to transmit the data obtained under sub-section (1), to another data controller or data processor without any hindrance.	Functional	Intersects With	Data Subject Empowerment	PRI-06	Mechanisms exist to provide authenticated data subjects the ability to: (1) Access their Personal Data (PD) that is being processed, stored and shared, except where the burden, risk or expense of providing access	8	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
IV.38(2)	Right to data portability	A data subject has the right to transmit the data obtained under sub-section (1), to another data controller or data processor without any hindrance.	Functional	Intersects With	Data Portability	PRI-06.6	Mechanisms exist to format exports of Personal Data (PD) in a structured, machine-readable format that allows data subjects to transfer their PD to another controller without hindrance.	5	
IV.38(2)	Right to data portability	A data subject has the right to transmit the data obtained under sub-section (1), to another data controller or data processor without any hindrance.	Functional	Intersects With	Personal Data (PD) Exports	PRI-06.7	Mechanisms exist to export a data subject's available Personal Data (PD) in a readily usable format, upon an authenticated request.	5	
IV.38(3)	Right to data portability	Where technically possible, the data subject shall have the right to have the personal data transmitted directly from one data controller or processor to another.	Functional	Intersects With	Data Subject Empowerment	PRI-06	Mechanisms exist to provide authenticated data subjects the ability to: (1) Access their Personal Data (PD) that is being processed, stored and shared, except where the burden, risk or expense of providing access	8	
IV.38(3)	Right to data portability	Where technically possible, the data subject shall have the right to have the personal data transmitted directly from one data controller or processor to another.	Functional	Intersects With	Data Portability	PRI-06.6	Mechanisms exist to format exports of Personal Data (PD) in a structured, machine-readable format that allows data subjects to transfer their PD to another controller without hindrance.	5	
IV.38(4)	Right to data portability	Where data controller or data processor declines to comply with a request under sub-section (3), the Data Commissioner may make a determination on the technical capacity of the data controller or data processor.	Functional	Intersects With	Data Subject Feedback Management	PRI-06.4	Mechanisms exist to maintain a process to efficiently and effectively respond to requests, complaints, concerns and/or questions from authenticated data subjects about Personal Data (PD) the organization	3	
IV.38(5)	Right to data portability	The right under this section shall not apply in circumstances where —	Functional	No Relationship	N/A	N/A	N/A	0	
IV.38(5)(a)	Right to data portability	processing may be necessary for the performance of a task carried out in the public interest or in the exercise of an official authority; or	Functional	No Relationship	N/A	N/A	N/A	0	
IV.38(5)(b)	Right to data portability	it may adversely affect the rights and freedoms of others.	Functional	No Relationship	N/A	N/A	N/A	0	
IV.38(6)	Right to data portability	A data controller or data processor shall comply with data portability requests, at reasonable cost and within a period of thirty days.	Functional	No Relationship	N/A	N/A	N/A	0	
IV.38(7)	Right to data portability	Where the portability request is complex or numerous, the period under sub-section (6) may be extended for a further period as may be determined	Functional	No Relationship	N/A	N/A	N/A	0	
IV.39	Limitation to retention of personal data	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
IV.39(1)	Limitation to retention of personal data	A data controller or data processor shall retain personal data only as long as may be reasonably necessary to satisfy the purpose for which it is processed unless the retention is — required or authorised by law;	Functional	Subset Of	Personal Data (PD) Retention & Disposal	PRI-05	Mechanisms exist to: (1) Retain Personal Data (PD), including metadata, for an organization-defined time period to fulfill the purpose(s) identified in the notice or as required by law;	10	
IV.39(1)(a)	Limitation to retention of personal data		Functional	Subset Of	Personal Data (PD) Retention & Disposal	PRI-05	Mechanisms exist to: (1) Retain Personal Data (PD), including metadata, for an organization-defined time period to fulfill the purpose(s) identified in the notice or as required by law; (2) Dispose of, destroys, erases, and/or anonymizes the PD, regardless of the method of storage; and (3) Use organization-defined techniques or methods to ensure secure deletion or destruction of PD (including originals, copies and archived records).	10	
IV.39(1)(b)	Limitation to retention of personal data	reasonably necessary for a lawful purpose;	Functional	Subset Of	Personal Data (PD) Retention & Disposal	PRI-05	Mechanisms exist to: (1) Retain Personal Data (PD), including metadata, for an organization-defined time period to fulfill the purpose(s) identified in the notice or as required by law; (2) Dispose of, destroys, erases, and/or anonymizes the PD, regardless of the method of storage; and (3) Use organization-defined techniques or methods to ensure secure deletion or destruction of PD (including originals, copies and archived records).	10	
IV.39(1)(c)	Limitation to retention of personal data	authorised or consented by the data subject; or	Functional	Subset Of	Personal Data (PD) Retention & Disposal	PRI-05	Mechanisms exist to: (1) Retain Personal Data (PD), including metadata, for an organization-defined time period to fulfill the purpose(s) identified in the notice or as required by law; (2) Dispose of, destroys, erases, and/or anonymizes the PD, regardless of the method of storage; and (3) Use organization-defined techniques or methods to ensure secure deletion or destruction of PD (including originals, copies and archived records).	10	
IV.39(1)(d)	Limitation to retention of personal data	for historical, statistical, journalistic literature and art or research purposes.	Functional	Subset Of	Personal Data (PD) Retention & Disposal	PRI-05	Mechanisms exist to: (1) Retain Personal Data (PD), including metadata, for an organization-defined time period to fulfill the purpose(s) identified in the notice or as required by law; (2) Dispose of, destroys, erases, and/or anonymizes the PD, regardless of the method of storage; and (3) Use organization-defined techniques or methods to ensure secure deletion or destruction of PD (including originals, copies and archived records).	10	
IV.39(2)	Limitation to retention of personal data	A data controller or data processor shall delete, erase, anonymise or pseudonymise personal data not necessary to be retained under sub-section (1) in a manner as may be specified at the expiry of the retention period.	Functional	Intersects With	De-identification (Anonymization)	DCH-23	Mechanisms exist to anonymize data by removing Personal Data (PD) from datasets.	8	
IV.39(2)	Limitation to retention of personal data	A data controller or data processor shall delete, erase, anonymise or pseudonymise personal data not necessary to be retained under sub-section (1) in a manner as may be specified at the expiry of the retention period.	Functional	Intersects With	Personal Data (PD) Retention & Disposal	PRI-05	Mechanisms exist to: (1) Retain Personal Data (PD), including metadata, for an organization-defined time period to fulfill the purpose(s) identified in the notice or as required by law;	8	
IV.40	Right of rectification and erasure	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
IV.40(1)	Right of rectification and erasure	A data subject may request a data controller or data processor —	Functional	Intersects With	Data Subject Empowerment	PRI-06	Mechanisms exist to provide authenticated data subjects the ability to: (1) Access their Personal Data (PD) that is being processed, stored and shared, except where the burden, risk or expense of providing access	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
IV.40(1)(a)	Right of rectification and erasure	to rectify without undue delay personal data in its possession or under its control that is inaccurate, out-dated, incomplete or misleading; or	Functional	Intersects With	Data Subject Empowerment	PRI-06	Mechanisms exist to provide authenticated data subjects the ability to: (1) Access their Personal Data (PD) that is being processed, stored and shared, except where the burden, risk or expense of providing access would be disproportionate to the benefit offered to the data subject through granting access; (2) Obtain answers on the specifics of how their PD is collected, received, processed, stored, transmitted, shared, updated and/or disposed; (3) Obtain the source(s) of their PD; (4) Obtain the categories of their PD being collected, received, processed, stored and shared; (5) Request correction to their PD due to inaccuracies; (6) Request erasure of their PD; and (7) Restrict the further collecting, receiving, processing, storing, transmitting, updated and/or sharing of their PD.	8	
IV.40(1)(a)	Right of rectification and erasure	to rectify without undue delay personal data in its possession or under its control that is inaccurate, out-dated, incomplete or misleading; or	Functional	Intersects With	Correcting Inaccurate Personal Data (PD)	PRI-06.1	Mechanisms exist to maintain a process for: (1) Data subjects to have inaccurate Personal Data (PD) maintained by the organization corrected or amended; and (2) Disseminating corrections or amendments of PD to other authorized users of the PD.	5	
IV.40(1)(b)	Right of rectification and erasure	to erase or destroy without undue delay personal data that the data controller or data processor is no longer authorised to retain, irrelevant, excessive or obtained unlawfully.	Functional	Intersects With	Data Subject Empowerment	PRI-06	Mechanisms exist to provide authenticated data subjects the ability to: (1) Access their Personal Data (PD) that is being processed, stored and shared, except where the burden, risk or expense of providing access would be disproportionate to the benefit offered to the data subject through granting access.	8	
IV.40(1)(b)	Right of rectification and erasure	to erase or destroy without undue delay personal data that the data controller or data processor is no longer authorised to retain, irrelevant, excessive or obtained unlawfully.	Functional	Intersects With	Right to Erasure	PRI-06.5	Mechanisms exist to maintain a process to erase a data subject's Personal Data (PD), in accordance with applicable laws, regulations and contractual obligations pertaining to the retention of their PD.	8	
IV.40(2)	Right of rectification and erasure	Where the data controller has shared the personal data with a third party for processing purposes, the data controller or data processor shall take all reasonable steps to inform third parties processing such data, that the data subject has requested —	Functional	Intersects With	Obligation To Inform Third-Parties	PRI-07.3	Mechanisms exist to inform applicable third-parties of any modification, deletion or other change that affects shared Personal Data (PD).	5	
IV.40(2)(a)	Right of rectification and erasure	the rectification of such personal data in their possession or under their control that is inaccurate, out-dated, incomplete or misleading; or	Functional	Intersects With	Data Privacy Requirements for Contractors & Service Providers	PRI-07.1	Mechanisms exist to include data privacy requirements in contracts and other acquisition-related documents that establish data privacy roles and responsibilities for contractors and service providers.	5	
IV.40(2)(b)	Right of rectification and erasure	the erasure or destruction of such personal data that the data controller is no longer authorised to retain, irrelevant, excessive or obtained unlawfully.	Functional	Intersects With	Data Privacy Requirements for Contractors & Service Providers	PRI-07.1	Mechanisms exist to include data privacy requirements in contracts and other acquisition-related documents that establish data privacy roles and responsibilities for contractors and service providers.	5	
IV.40(3)	Right of rectification and erasure	Where a data controller or data processor is required to rectify or erase personal data under sub-section (1), but the personal data is required for the purposes of evidence, the data controller or data processor shall, instead of erasing or rectifying, restrict its processing and inform the data subject within a reasonable time.	Functional	Intersects With	Right to Erasure	PRI-06.5	Mechanisms exist to maintain a process to erase a data subject's Personal Data (PD), in accordance with applicable laws, regulations and contractual obligations pertaining to the retention of their PD.	8	
IV.40(3)	Right of rectification and erasure	Where a data controller or data processor is required to rectify or erase personal data under sub-section (1), but the personal data is required for the purposes of evidence, the data controller or data processor shall, instead of erasing or rectifying, restrict its processing and inform the data subject within a reasonable time.	Functional	Intersects With	Data Privacy Requirements for Contractors & Service Providers	PRI-07.1	Mechanisms exist to include data privacy requirements in contracts and other acquisition-related documents that establish data privacy roles and responsibilities for contractors and service providers.	5	
IV.40(3)	Right of rectification and erasure	Where a data controller or data processor is required to rectify or erase personal data under sub-section (1), but the personal data is required for the purposes of evidence, the data controller or data processor shall, instead of erasing or rectifying, restrict its processing and inform the data subject within a reasonable time.	Functional	Intersects With	Obligation To Inform Third-Parties	PRI-07.3	Mechanisms exist to inform applicable third-parties of any modification, deletion or other change that affects shared Personal Data (PD).	8	
IV.41	Data protection by design or by default	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
IV.41(1)	Data protection by design or by default	Every data controller or data processor shall implement appropriate technical and organisational measures which are designed —	Functional	Subset Of	Security of Personal Data (PD)	PRI-01.6	Mechanisms exist to ensure Personal Data (PD) is protected by logical and physical security safeguards that are sufficient and appropriately scoped to protect the confidentiality and integrity of the PD.	10	
IV.41(1)(a)	Data protection by design or by default	to implement the data protection principles in an effective manner; and	Functional	Subset Of	Security of Personal Data (PD)	PRI-01.6	Mechanisms exist to ensure Personal Data (PD) is protected by logical and physical security safeguards that are sufficient and appropriately scoped to protect the confidentiality and integrity of the PD.	10	
IV.41(1)(b)	Data protection by design or by default	to integrate necessary safeguards for that purpose into the processing.	Functional	Subset Of	Security of Personal Data (PD)	PRI-01.6	Mechanisms exist to ensure Personal Data (PD) is protected by logical and physical security safeguards that are sufficient and appropriately scoped to protect the confidentiality and integrity of the PD.	10	
IV.41(2)	Data protection by design or by default	The duty under subsection (1) applies both at the time of the determination of the means of processing the data and at the time of the processing.	Functional	Subset Of	Security of Personal Data (PD)	PRI-01.6	Mechanisms exist to ensure Personal Data (PD) is protected by logical and physical security safeguards that are sufficient and appropriately scoped to protect the confidentiality and integrity of the PD.	10	
IV.41(3)	Data protection by design or by default	A data controller or data processor shall implement appropriate technical and organisational measures for ensuring that, by default, only personal data which is necessary for each specific purpose is processed, taking into consideration —	Functional	Subset Of	Security of Personal Data (PD)	PRI-01.6	Mechanisms exist to ensure Personal Data (PD) is protected by logical and physical security safeguards that are sufficient and appropriately scoped to protect the confidentiality and integrity of the PD.	10	
IV.41(3)(a)	Data protection by design or by default	the amount of personal data collected;	Functional	Subset Of	Security of Personal Data (PD)	PRI-01.6	Mechanisms exist to ensure Personal Data (PD) is protected by logical and physical security safeguards that are sufficient and appropriately scoped to protect the confidentiality and integrity of the PD.	10	
IV.41(3)(b)	Data protection by design or by default	the extent of its processing;	Functional	Subset Of	Security of Personal Data (PD)	PRI-01.6	Mechanisms exist to ensure Personal Data (PD) is protected by logical and physical security safeguards that are sufficient and appropriately scoped to protect the confidentiality and integrity of the PD.	10	
IV.41(3)(c)	Data protection by design or by default	the period of its storage;	Functional	Subset Of	Security of Personal Data (PD)	PRI-01.6	Mechanisms exist to ensure Personal Data (PD) is protected by logical and physical security safeguards that are sufficient and appropriately scoped to protect the confidentiality and integrity of the PD.	10	
IV.41(3)(d)	Data protection by design or by default	its accessibility; and	Functional	Subset Of	Security of Personal Data (PD)	PRI-01.6	Mechanisms exist to ensure Personal Data (PD) is protected by logical and physical security safeguards that are sufficient and appropriately scoped to protect the confidentiality and integrity of the PD.	10	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
IV.41(3)(e)	Data protection by design or by default	the cost of processing data and the technologies and tools used.	Functional	Subset Of	Security of Personal Data (PD)	PRI-01.6	Mechanisms exist to ensure Personal Data (PD) is protected by logical and physical security safeguards that are sufficient and appropriately scoped to protect the confidentiality and integrity of the PD.	10	
IV.41(4)	Data protection by design or by default	To give effect to this section, the data controller or data processor shall consider measures such as —	Functional	Subset Of	Security of Personal Data (PD)	PRI-01.6	Mechanisms exist to ensure Personal Data (PD) is protected by logical and physical security safeguards that are sufficient and appropriately scoped to protect the confidentiality and integrity of the PD.	10	
IV.41(4)(a)	Data protection by design or by default	to identify reasonably foreseeable internal and external risks to personal data under the person's possession or control;	Functional	Subset Of	Security of Personal Data (PD)	PRI-01.6	Mechanisms exist to ensure Personal Data (PD) is protected by logical and physical security safeguards that are sufficient and appropriately scoped to protect the confidentiality and integrity of the PD.	10	
IV.41(4)(b)	Data protection by design or by default	to establish and maintain appropriate safeguards against the identified risks;	Functional	Subset Of	Security of Personal Data (PD)	PRI-01.6	Mechanisms exist to ensure Personal Data (PD) is protected by logical and physical security safeguards that are sufficient and appropriately scoped to protect the confidentiality and integrity of the PD.	10	
IV.41(4)(c)	Data protection by design or by default	to the pseudonymisation and encryption of personal data;	Functional	Subset Of	Security of Personal Data (PD)	PRI-01.6	Mechanisms exist to ensure Personal Data (PD) is protected by logical and physical security safeguards that are sufficient and appropriately scoped to protect the confidentiality and integrity of the PD.	10	
IV.41(4)(d)	Data protection by design or by default	to the ability to restore the availability and access to personal data in a timely manner in the event of a physical or technical incident;	Functional	Subset Of	Security of Personal Data (PD)	PRI-01.6	Mechanisms exist to ensure Personal Data (PD) is protected by logical and physical security safeguards that are sufficient and appropriately scoped to protect the confidentiality and integrity of the PD.	10	
IV.41(4)(e)	Data protection by design or by default	to verify that the safeguards are effectively implemented; and	Functional	Subset Of	Security of Personal Data (PD)	PRI-01.6	Mechanisms exist to ensure Personal Data (PD) is protected by logical and physical security safeguards that are sufficient and appropriately scoped to protect the confidentiality and integrity of the PD.	10	
IV.41(4)(f)	Data protection by design or by default	to ensure that the safeguards are continually updated in response to new risks or deficiencies.	Functional	Subset Of	Security of Personal Data (PD)	PRI-01.6	Mechanisms exist to ensure Personal Data (PD) is protected by logical and physical security safeguards that are sufficient and appropriately scoped to protect the confidentiality and integrity of the PD.	10	
IV.42	Particulars of determining organisational measures	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
IV.42(1)	Particulars of determining organisational measures	In determining the appropriate measures referred to in section 41, in particular, where the processing involves the transmission of data over an information and communication network, a data controller shall have regard to —	Functional	Subset Of	Security of Personal Data (PD)	PRI-01.6	Mechanisms exist to ensure Personal Data (PD) is protected by logical and physical security safeguards that are sufficient and appropriately scoped to protect the confidentiality and integrity of the PD.	10	
IV.42(1)(a)	Particulars of determining organisational measures	the state of technological development available;	Functional	Subset Of	Security of Personal Data (PD)	PRI-01.6	Mechanisms exist to ensure Personal Data (PD) is protected by logical and physical security safeguards that are sufficient and appropriately scoped to protect the confidentiality and integrity of the PD.	10	
IV.42(1)(b)	Particulars of determining organisational measures	the cost of implementing any of the security measures;	Functional	Subset Of	Security of Personal Data (PD)	PRI-01.6	Mechanisms exist to ensure Personal Data (PD) is protected by logical and physical security safeguards that are sufficient and appropriately scoped to protect the confidentiality and integrity of the PD.	10	
IV.42(1)(c)	Particulars of determining organisational measures	the special risks that exist in the processing of the data; and	Functional	Subset Of	Security of Personal Data (PD)	PRI-01.6	Mechanisms exist to ensure Personal Data (PD) is protected by logical and physical security safeguards that are sufficient and appropriately scoped to protect the confidentiality and integrity of the PD.	10	
IV.42(1)(d)	Particulars of determining organisational measures	the nature of the data being processed.	Functional	Subset Of	Security of Personal Data (PD)	PRI-01.6	Mechanisms exist to ensure Personal Data (PD) is protected by logical and physical security safeguards that are sufficient and appropriately scoped to protect the confidentiality and integrity of the PD.	10	
IV.42(2)	Particulars of determining organisational measures	Where a data controller is using the services of a data processor —	Functional	Subset Of	Security of Personal Data (PD)	PRI-01.6	Mechanisms exist to ensure Personal Data (PD) is protected by logical and physical security safeguards that are sufficient and appropriately scoped to protect the confidentiality and integrity of the PD.	10	
IV.42(2)(a)	Particulars of determining organisational measures	the data controller shall opt for a data processor who provides sufficient guarantees in respect of organisational measures for the purpose of complying with section 41 (1); and	Functional	Intersects With	Security of Personal Data (PD)	PRI-01.6	Mechanisms exist to ensure Personal Data (PD) is protected by logical and physical security safeguards that are sufficient and appropriately scoped to protect the confidentiality and integrity of the PD.	5	
IV.42(2)(a)	Particulars of determining organisational measures	the data controller shall opt for a data processor who provides sufficient guarantees in respect of organisational measures for the purpose of complying with section 41 (1); and	Functional	Intersects With	Data Privacy Requirements for Contractors & Service Providers	PRI-07.1	Mechanisms exist to include data privacy requirements in contracts and other acquisition-related documents that establish data privacy roles and responsibilities for contractors and service providers.	5	
IV.42(2)(b)	Particulars of determining organisational measures	the data controller and the data processor shall enter into a written contract which shall provide that the data processor shall act only on instructions received from the data controller and shall be bound by obligations of the data controller.	Functional	Intersects With	Security of Personal Data (PD)	PRI-01.6	Mechanisms exist to ensure Personal Data (PD) is protected by logical and physical security safeguards that are sufficient and appropriately scoped to protect the confidentiality and integrity of the PD.	5	
IV.42(2)(b)	Particulars of determining organisational measures	the data controller and the data processor shall enter into a written contract which shall provide that the data processor shall act only on instructions received from the data controller and shall be bound by obligations of the data controller.	Functional	Intersects With	Data Privacy Requirements for Contractors & Service Providers	PRI-07.1	Mechanisms exist to include data privacy requirements in contracts and other acquisition-related documents that establish data privacy roles and responsibilities for contractors and service providers.	5	
IV.42(3)	Particulars of determining organisational measures	Where a data processor processes personal data other than as instructed by the data controller, the data processor shall be deemed to be a data controller in respect of that processing.	Functional	Intersects With	Security of Personal Data (PD)	PRI-01.6	Mechanisms exist to ensure Personal Data (PD) is protected by logical and physical security safeguards that are sufficient and appropriately scoped to protect the confidentiality and integrity of the PD.	5	
IV.42(3)	Particulars of determining organisational measures	Where a data processor processes personal data other than as instructed by the data controller, the data processor shall be deemed to be a data controller in respect of that processing.	Functional	Intersects With	Data Privacy Requirements for Contractors & Service Providers	PRI-07.1	Mechanisms exist to include data privacy requirements in contracts and other acquisition-related documents that establish data privacy roles and responsibilities for contractors and service providers.	5	
IV.42(4)	Particulars of determining organisational measures	A data controller or data processor shall take all reasonable steps to ensure that any person employed by or acting under the authority of the data controller or data processor, complies with the relevant security measures.	Functional	Intersects With	Security of Personal Data (PD)	PRI-01.6	Mechanisms exist to ensure Personal Data (PD) is protected by logical and physical security safeguards that are sufficient and appropriately scoped to protect the confidentiality and integrity of the PD.	5	
IV.42(4)	Particulars of determining organisational measures	A data controller or data processor shall take all reasonable steps to ensure that any person employed by or acting under the authority of the data controller or data processor, complies with the relevant security measures.	Functional	Intersects With	Data Privacy Requirements for Contractors & Service Providers	PRI-07.1	Mechanisms exist to include data privacy requirements in contracts and other acquisition-related documents that establish data privacy roles and responsibilities for contractors and service providers.	5	
IV.43	Notification and communication of breach	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
IV.43(1)	Notification and communication of breach	Where personal data has been accessed or acquired by an unauthorised person, and there is a real risk of harm to the data subject whose personal data has been subjected to the unauthorised access, a data controller notify the Data Commissioner without delay, within seventy-two hours of becoming aware of such breach; and	Functional	No Relationship	N/A	N/A	N/A	0	
IV.43(1)(a)	Notification and communication of breach	subject to subsection (3), communicate to the data subject in writing within a reasonably practical period, unless the identity of the data subject cannot be established.	Functional	Intersects With	Cyber Incident Reporting for Sensitive / Regulated Data	IRO-10.2	Mechanisms exist to report sensitive and/or regulated data incidents in a timely manner.	8	
IV.43(1)(b)	Notification and communication of breach	Where the notification to the Data Commissioner is not made within seventy-two hours, the notification shall be accompanied by reasons for the delay	Functional	Intersects With	Incident Stakeholder Reporting	IRO-10	Mechanisms exist to timely-report incidents to applicable: (1) Internal stakeholders; (2) Affected clients & third-parties; and (3) Regulatory authorities.	8	
IV.43(2)	Notification and communication of breach	Where a data processor becomes aware of a personal data breach, the data processor shall notify the data controller without delay and where reasonably practicable, within forty-eight hours of becoming aware of such breach.	Functional	Intersects With	Incident Stakeholder Reporting	IRO-10	Mechanisms exist to timely-report incidents to applicable: (1) Internal stakeholders; (2) Affected clients & third-parties; and (3) Regulatory authorities.	8	
IV.43(3)	Notification and communication of breach	The data controller may delay or restrict communication referred to under subsection (1) (b) as necessary and proportionate for purposes of prevention, detection or investigation of an offence by the concerned relevant body.	Functional	Intersects With	Incident Stakeholder Reporting	IRO-10	Mechanisms exist to timely-report incidents to applicable: (1) Internal stakeholders; (2) Affected clients & third-parties; and (3) Regulatory authorities.	8	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
IV.43(5)	Notification and communication of breach	The notification and communication referred to under subsection (1) shall provide sufficient information to allow the data subject to take protective measures against the potential consequences of the data breach, including — description of the nature of the data breach;	Functional	Intersects With	Incident Stakeholder Reporting	IRO-10	Mechanisms exist to timely-report incidents to applicable: (1) Internal stakeholders; (2) Affected clients & third-parties; and (3) Regulatory authorities.	5	
IV.43(5)(a)	Notification and communication of breach		Functional	Intersects With	Incident Stakeholder Reporting	IRO-10	Mechanisms exist to timely-report incidents to applicable: (1) Internal stakeholders; (2) Affected clients & third-parties; and (3) Regulatory authorities.	8	
IV.43(5)(b)	Notification and communication of breach	description of the measures that the data controller or data processor intends to take or has taken to address the data breach;	Functional	Intersects With	Incident Stakeholder Reporting	IRO-10	Mechanisms exist to timely-report incidents to applicable: (1) Internal stakeholders; (2) Affected clients & third-parties; and (3) Regulatory authorities.	8	
IV.43(5)(c)	Notification and communication of breach	recommendation on the measures to be taken by the data subject to mitigate the adverse effects of the security compromise;	Functional	Intersects With	Incident Stakeholder Reporting	IRO-10	Mechanisms exist to timely-report incidents to applicable: (1) Internal stakeholders; (2) Affected clients & third-parties; and (3) Regulatory authorities.	8	
IV.43(5)(d)	Notification and communication of breach	where applicable, the identity of the unauthorised person who may have accessed or acquired the personal data; and	Functional	Intersects With	Incident Stakeholder Reporting	IRO-10	Mechanisms exist to timely-report incidents to applicable: (1) Internal stakeholders; (2) Affected clients & third-parties; and (3) Regulatory authorities.	8	
IV.43(5)(e)	Notification and communication of breach	the name and contact details of the data protection officer where applicable or other contact point from whom more information could be obtained.	Functional	Intersects With	Incident Stakeholder Reporting	IRO-10	Mechanisms exist to timely-report incidents to applicable: (1) Internal stakeholders; (2) Affected clients & third-parties; and (3) Regulatory authorities.	8	
IV.43(6)	Notification and communication of breach	The communication of a breach to the data subject shall not be required where the data controller or data processor has implemented appropriate security safeguards which may include encryption of affected personal data.	Functional	Intersects With	Incident Stakeholder Reporting	IRO-10	Mechanisms exist to timely-report incidents to applicable: (1) Internal stakeholders; (2) Affected clients & third-parties; and (3) Regulatory authorities.	8	
IV.43(7)	Notification and communication of breach	Where and to the extent that it is not possible to provide all the information mentioned in subsection (5) at the same time, the information may be provided in phases without undue delay.	Functional	Intersects With	Incident Stakeholder Reporting	IRO-10	Mechanisms exist to timely-report incidents to applicable: (1) Internal stakeholders; (2) Affected clients & third-parties; and (3) Regulatory authorities.	8	
IV.43(8)	Notification and communication of breach	The data controller shall record the following information in relation to a personal data breach—	Functional	Intersects With	Incident Stakeholder Reporting	IRO-10	Mechanisms exist to timely-report incidents to applicable: (1) Internal stakeholders; (2) Affected clients & third-parties; and (3) Regulatory authorities.	5	
IV.43(8)(a)	Notification and communication of breach	the facts relating to the breach;	Functional	Intersects With	Incident Stakeholder Reporting	IRO-10	Mechanisms exist to timely-report incidents to applicable: (1) Internal stakeholders; (2) Affected clients & third-parties; and (3) Regulatory authorities.	8	
IV.43(8)(b)	Notification and communication of breach	its effects; and	Functional	Intersects With	Incident Stakeholder Reporting	IRO-10	Mechanisms exist to timely-report incidents to applicable: (1) Internal stakeholders; (2) Affected clients & third-parties; and (3) Regulatory authorities.	8	
IV.43(8)(c)	Notification and communication of breach	the remedial action taken.	Functional	Intersects With	Incident Stakeholder Reporting	IRO-10	Mechanisms exist to timely-report incidents to applicable: (1) Internal stakeholders; (2) Affected clients & third-parties; and (3) Regulatory authorities.	8	
V	FOUNDATIONS FOR PROCESSING OF SENSITIVE PERSONAL DATA	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
V.44	Processing of sensitive personal data	See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	
V.45	Permitted grounds for processing sensitive personal data	Without prejudice to section 44, sensitive personal data of a data subject may be processed where —	Functional	Intersects With	Usage Restrictions of Personal Data (PD)	PRI-05.4	Mechanisms exist to restrict collecting, receiving, processing, storing, transmitting, sharing and/or updating Personal Data (PD) to: (1) The purpose(s) originally collected, consistent with the data privacy notice(s);	5	
V.45(a)	Permitted grounds for processing sensitive personal data	the processing is carried out in the course of legitimate activities with appropriate safeguards by a foundation, association or any other not-for-profit body with a political, philosophical, religious or trade union aim and on condition that —	Functional	Intersects With	Usage Restrictions of Personal Data (PD)	PRI-05.4	Mechanisms exist to restrict collecting, receiving, processing, storing, transmitting, sharing and/or updating Personal Data (PD) to: (1) The purpose(s) originally collected, consistent with the data privacy notice(s); (2) What is authorized by the data subject, or authorized agent; and (3) What is consistent with applicable laws, regulations and contractual obligations.	5	
V.45(a)(i)	Permitted grounds for processing sensitive personal data	the processing relates solely to the members of the body or to persons who have regular contact with it in connection with its purposes; and	Functional	Intersects With	Usage Restrictions of Personal Data (PD)	PRI-05.4	Mechanisms exist to restrict collecting, receiving, processing, storing, transmitting, sharing and/or updating Personal Data (PD) to: (1) The purpose(s) originally collected, consistent with the data privacy notice(s); (2) What is authorized by the data subject, or authorized agent; and (3) What is consistent with applicable laws, regulations and contractual obligations.	5	
V.45(a)(ii)	Permitted grounds for processing sensitive personal data	the personal data is not disclosed outside that body without the consent of the data subject.	Functional	Intersects With	Usage Restrictions of Personal Data (PD)	PRI-05.4	Mechanisms exist to restrict collecting, receiving, processing, storing, transmitting, sharing and/or updating Personal Data (PD) to: (1) The purpose(s) originally collected, consistent with the data privacy notice(s); (2) What is authorized by the data subject, or authorized agent; and (3) What is consistent with applicable laws, regulations and contractual obligations.	5	
V.45(b)	Permitted grounds for processing sensitive personal data	the processing relates to personal data which is manifestly made public by the data subject; or	Functional	Intersects With	Usage Restrictions of Personal Data (PD)	PRI-05.4	Mechanisms exist to restrict collecting, receiving, processing, storing, transmitting, sharing and/or updating Personal Data (PD) to: (1) The purpose(s) originally collected, consistent with the data privacy notice(s); (2) What is authorized by the data subject, or authorized agent; and (3) What is consistent with applicable laws, regulations and contractual obligations.	5	
V.45(c)	Permitted grounds for processing sensitive personal data	processing is necessary for—	Functional	Intersects With	Usage Restrictions of Personal Data (PD)	PRI-05.4	Mechanisms exist to restrict collecting, receiving, processing, storing, transmitting, sharing and/or updating Personal Data (PD) to: (1) The purpose(s) originally collected, consistent with the data privacy notice(s); (2) What is authorized by the data subject, or authorized agent; and (3) What is consistent with applicable laws, regulations and contractual obligations.	5	
V.45(c)(i)	Permitted grounds for processing sensitive personal data	the establishment, exercise or defence of a legal claim;	Functional	Intersects With	Usage Restrictions of Personal Data (PD)	PRI-05.4	Mechanisms exist to restrict collecting, receiving, processing, storing, transmitting, sharing and/or updating Personal Data (PD) to: (1) The purpose(s) originally collected, consistent with the data privacy notice(s); (2) What is authorized by the data subject, or authorized agent; and (3) What is consistent with applicable laws, regulations and contractual obligations.	5	
V.45(c)(ii)	Permitted grounds for processing sensitive personal data	the purpose of carrying out the obligations and exercising specific rights of the controller or of the data subject; or	Functional	Intersects With	Usage Restrictions of Personal Data (PD)	PRI-05.4	Mechanisms exist to restrict collecting, receiving, processing, storing, transmitting, sharing and/or updating Personal Data (PD) to: (1) The purpose(s) originally collected, consistent with the data privacy notice(s); (2) What is authorized by the data subject, or authorized agent; and (3) What is consistent with applicable laws, regulations and contractual obligations.	5	
V.45(c)(iii)	Permitted grounds for processing sensitive personal data	protecting the vital interests of the data subject or another person where the data subject is physically or legally incapable of giving consent.	Functional	Intersects With	Usage Restrictions of Personal Data (PD)	PRI-05.4	Mechanisms exist to restrict collecting, receiving, processing, storing, transmitting, sharing and/or updating Personal Data (PD) to: (1) The purpose(s) originally collected, consistent with the data privacy notice(s); (2) What is authorized by the data subject, or authorized agent; and (3) What is consistent with applicable laws, regulations and contractual obligations.	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
V.46	Personal data relating to health	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
V.46(1)	Personal data relating to health	Personal data relating to the health of a data subject may only be processed— by or under the responsibility of a health care provider; or	Functional	Intersects With	Usage Restrictions of Personal Data (PD)	PRI-05.4	Mechanisms exist to restrict collecting, receiving, processing, storing, transmitting, sharing and/or updating Personal Data (PD) to:	5	
V.46(1)(a)	Personal data relating to health		Functional	Intersects With	Usage Restrictions of Personal Data (PD)	PRI-05.4	Mechanisms exist to restrict collecting, receiving, processing, storing, transmitting, sharing and/or updating Personal Data (PD) to: (1) The purpose(s) originally collected, consistent with the data privacy notice(s); (2) What is authorized by the data subject, or authorized agent; and (3) What is consistent with applicable laws, regulations and contractual obligations.	5	
V.46(1)(b)	Personal data relating to health	by a person subject to the obligation of professional secrecy under any law.	Functional	Intersects With	Usage Restrictions of Personal Data (PD)	PRI-05.4	Mechanisms exist to restrict collecting, receiving, processing, storing, transmitting, sharing and/or updating Personal Data (PD) to: (1) The purpose(s) originally collected, consistent with the data privacy notice(s); (2) What is authorized by the data subject, or authorized agent; and (3) What is consistent with applicable laws, regulations and contractual obligations.	5	
V.46(2)	Personal data relating to health	The condition under subsection (1) is met if the processing —	Functional	No Relationship	N/A	N/A	N/A	0	
V.46(2)(a)	Personal data relating to health	is necessary for reasons of public interest in the area of public health; or	Functional	Intersects With	Usage Restrictions of Personal Data (PD)	PRI-05.4	Mechanisms exist to restrict collecting, receiving, processing, storing, transmitting, sharing and/or updating Personal Data (PD) to:	5	
V.46(2)(b)	Personal data relating to health	is carried out by another person who in the circumstances owes a duty of confidentiality under any law.	Functional	Intersects With	Usage Restrictions of Personal Data (PD)	PRI-05.4	Mechanisms exist to restrict collecting, receiving, processing, storing, transmitting, sharing and/or updating Personal Data (PD) to: (1) The purpose(s) originally collected, consistent with the data privacy notice(s); (2) What is authorized by the data subject, or authorized agent; and (3) What is consistent with applicable laws, regulations and contractual obligations.	5	
V.47	Further categories of sensitive personal data	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
V.47(1)	Further categories of sensitive personal data	The Data Commissioner may prescribe further categories of personal data which may be classified as sensitive personal data.	Functional	No Relationship	N/A	N/A	N/A	0	
V.47(2)	Further categories of sensitive personal data	Where categories of personal data have been specified as sensitive personal data under subsection (1), the Data Commissioner may specify any further grounds on which such specified categories may be processed,	Functional	No Relationship	N/A	N/A	N/A	0	
V.47(2)(a)	Further categories of sensitive personal data	to the risk of significant harm that may be caused to a data subject by the processing of such category of personal data;	Functional	No Relationship	N/A	N/A	N/A	0	
V.47(2)(b)	Further categories of sensitive personal data	to the expectation of confidentiality attached to such category of personal data;	Functional	No Relationship	N/A	N/A	N/A	0	
V.47(2)(c)	Further categories of sensitive personal data	to whether a significantly discernible class of data subjects may suffer significant harm from the processing of such category of personal data; and	Functional	No Relationship	N/A	N/A	N/A	0	
V.47(2)(d)	Further categories of sensitive personal data	to the adequacy of protection afforded by ordinary provisions applicable to personal data.	Functional	No Relationship	N/A	N/A	N/A	0	
V.47(3)	Further categories of sensitive personal data	The Data Commissioner may specify other categories of personal data, which may require additional safeguards or restrictions.	Functional	No Relationship	N/A	N/A	N/A	0	
VI	TRANSFER OF PERSONAL DATA OUTSIDE KENYA	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
VI.48	Conditions for transfer out of Kenya	A data controller or data processor may transfer personal data to another country only where —	Functional	No Relationship	N/A	N/A	N/A	0	
VI.48(a)	Conditions for transfer out of Kenya	the data controller or data processor has given proof to the Data Commissioner on the appropriate safeguards with respect to the security and protection of the personal data;	Functional	No Relationship	N/A	N/A	N/A	0	
VI.48(b)	Conditions for transfer out of Kenya	the data controller or data processor has given proof to the Data Commissioner of the appropriate safeguards with respect to the security and protection of personal data, and the appropriate safeguards including the transfer is necessary —	Functional	No Relationship	N/A	N/A	N/A	0	
VI.48(c)	Conditions for transfer out of Kenya		Functional	No Relationship	N/A	N/A	N/A	0	
VI.48(c)(i)	Conditions for transfer out of Kenya	for the performance of a contract between the data subject and the data controller or data processor or implementation of precontractual measures taken at the data subject's request;	Functional	No Relationship	N/A	N/A	N/A	0	
VI.48(c)(ii)	Conditions for transfer out of Kenya	for the conclusion or performance of a contract concluded in the interest of the data subject between the controller and another person;	Functional	No Relationship	N/A	N/A	N/A	0	
VI.48(c)(iii)	Conditions for transfer out of Kenya	for any matter of public interest;	Functional	No Relationship	N/A	N/A	N/A	0	
VI.48(c)(iv)	Conditions for transfer out of Kenya	for the establishment, exercise or defence of a legal claim;	Functional	No Relationship	N/A	N/A	N/A	0	
VI.48(c)(v)	Conditions for transfer out of Kenya	in order to protect the vital interests of the data subject or of other persons, where the data subject is physically or legally incapable of giving consent; or	Functional	No Relationship	N/A	N/A	N/A	0	
VI.48(c)(vi)	Conditions for transfer out of Kenya	for the purpose of compelling legitimate interests pursued by the data controller or data processor which are not overridden by the interests, rights and freedoms of the data subjects.	Functional	No Relationship	N/A	N/A	N/A	0	
VI.49	Safeguards prior to transfer of personal data out	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
VI.49(1)	Safeguards prior to transfer of personal data out of Kenya	The processing of sensitive personal data out of Kenya shall only be effected upon obtaining consent of a data subject and on obtaining confirmation of appropriate safeguards.	Functional	Intersects With	Binding Corporate Rules (BCR)	PRI-01.5	Mechanisms exist to implement and manage Binding Corporate Rules (BCR) (e.g., data sharing agreement) to legally bind all parties engaged in a joint economic activity that contractually states enforceable rights on data subjects with regard to the processing of their personal data.	8	
VI.49(2)	Safeguards prior to transfer of personal data out of Kenya	The Data Commissioner may request a person who transfers data to another country to demonstrate the effectiveness of the security safeguards or the existence of compelling legitimate interests.	Functional	Intersects With	Binding Corporate Rules (BCR)	PRI-01.5	Mechanisms exist to implement and manage Binding Corporate Rules (BCR) (e.g., data sharing agreement) to legally bind all parties engaged in a joint economic activity that contractually states enforceable rights on data subjects with regard to the processing of their personal data.	5	
VI.49(3)	Safeguards prior to transfer of personal data out of Kenya	The Data Commissioner may, in order to protect the rights and fundamental freedoms of data subjects, prohibit, suspend or subject the transfer to such conditions as may be determined.	Functional	Intersects With	Binding Corporate Rules (BCR)	PRI-01.5	Mechanisms exist to implement and manage Binding Corporate Rules (BCR) (e.g., data sharing agreement) to legally bind all parties engaged in a joint economic activity that contractually states enforceable rights on data subjects with regard to the processing of their personal data.	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
VI.50	Processing through a data server or data centre in Kenya	The Cabinet Secretary may prescribe, based on grounds of strategic interests of the state or protection of revenue, certain nature of processing that shall only be effected through a server or a data centre located in Kenya	Functional	Intersects With	Binding Corporate Rules (BCR)	PRI-01.5	Mechanisms exist to implement and manage Binding Corporate Rules (BCR) (e.g., data sharing agreement) to legally-bind all parties engaged in a joint economic activity that contractually states enforceable rights on data subjects with regard to the processing of their personal data.	3	
VII	EXEMPTIONS	See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	
VIII	ENFORCEMENT PROVISIONS	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
VIII.56	Complaints to the Data Commissioner	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
VIII.56(1)	Complaints to the Data Commissioner	A data subject who is aggrieved by a decision of any person under this Act may lodge a complaint with the Data Commissioner in accordance with this Act.	Functional	No Relationship	N/A	N/A	N/A	0	
VIII.56(2)	Complaints to the Data Commissioner	A person who intends to lodge a complaint under this Act shall do so orally or in writing.	Functional	No Relationship	N/A	N/A	N/A	0	
VIII.56(3)	Complaints to the Data Commissioner	Where a complaint made under subclause (1) is made orally, the Data Commissioner shall cause the complaint to be recorded in writing and the complaint shall be dealt with in accordance with such procedures as the Data Commissioner may prescribe.	Functional	No Relationship	N/A	N/A	N/A	0	
VIII.56(4)	Complaints to the Data Commissioner	A complaint lodged under subclause (1) shall contain such particulars as the Data Commissioner may prescribe.	Functional	No Relationship	N/A	N/A	N/A	0	
VIII.56(5)	Complaints to the Data Commissioner	A complaint made to the Data Commissioner shall be investigated and concluded within ninety days.	Functional	No Relationship	N/A	N/A	N/A	0	
VIII.57	Investigation of complaints	See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	
VIII.58	Enforcement notices	See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	
VIII.59	Power to seek assistance	See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	
VIII.60	Power of entry and search	See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	
VIII.61	Obstruction of Data	See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	
VIII.62	Penalty notices	See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	
VIII.63	Administrative fines	See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	
VIII.64	Right of appeal	See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	
VIII.65	Compensation to a data subject	See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	
VIII.66	Preservation Order	See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	
IX	FINANCIAL PROVISIONS	See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	
X	PROVISIONS ON DELEGATED POWERS	See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	
XI	MISCELLANEOUS PROVISIONS	See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	